

Incident Response Runbook

Northwind Analytics Ltd · NW-SEC-012 · Revision 6 · Classification: Internal

1. Scope and principles

This runbook describes how Northwind Analytics Ltd responds to a suspected information security incident. It is written to be followed under pressure by someone who has not read it recently, so it favours explicit instruction over discussion.

Three principles govern every decision during a response. Preserve evidence before attempting remediation. Communicate early and imprecisely rather than late and precisely. Assume the reporter is right until the investigation shows otherwise.

2. What counts as an incident

An incident is any event that may compromise the confidentiality, integrity, or availability of Company or client information. Certainty is not required to report; suspicion is sufficient and is the intended threshold.

- Suspected phishing, whether or not anyone interacted with it.
- Malware detected or suspected on any device.
- Loss or theft of any device holding Company data or credentials.
- Credentials, API keys, or private keys exposed in any way, including in a private repository, a ticket, or a chat message.
- Information sent to the wrong recipient.
- Unexpected system behaviour that cannot be readily explained.
- Any external request for information or access that seems unusual in its urgency, its channel, or its claimed authority.

3. Immediate actions on discovery

Report first. Contact Security Operations through the incident line or the #security-incidents channel. Do not wait to confirm your suspicion, gather more detail, or check with a colleague.

Do not investigate, contain, or remediate unless explicitly instructed. Well-intentioned action routinely destroys the evidence needed to establish scope. Do not power off an affected machine; disconnect it from the network if instructed and leave it running, because memory contents are frequently the only record of what executed.

Do not discuss the incident outside the response channel, including with colleagues who are not involved. Where a compromise of communications is possible, the response team will move to an out-of-band channel and will tell you which one.

4. Severity classification

Severity is assigned by the Incident Commander within 30 minutes of triage and is reviewed at every checkpoint. It may be raised or lowered as understanding improves; both directions are normal and neither is a criticism of the initial call.

- **SEV1 — Critical.** Confirmed compromise of production, confirmed exfiltration of Confidential or Restricted data, ransomware, or any incident affecting client data. Executive Committee notified immediately. Response is continuous.
- **SEV2 — High.** Confirmed compromise of a non-production system, credential compromise with no evidence of use, or malware contained on a single endpoint. Response during extended hours.
- **SEV3 — Moderate.** Suspected but unconfirmed compromise, policy violation with security implications, or a near miss worth investigating.

5. Roles

The Incident Commander owns the response and is the single decision-maker. They do not perform technical work; their job is to hold the whole picture, and someone deep in a log file cannot do that.

The Communications Lead owns all internal and external messaging, including to clients and regulators. No one else communicates about the incident outside the response team.

The Scribe maintains the timeline: what was observed, when, by whom, and what was done in response. The timeline is written contemporaneously, never reconstructed afterwards.

Technical Responders investigate and remediate as directed. Where a responder disagrees with a decision, they say so once, clearly, and then execute — and the disagreement is recorded in the timeline for the post-incident review.

6. Containment, eradication, recovery

Containment limits further damage: isolating hosts, revoking sessions and credentials, blocking indicators, and disabling affected accounts. Containment decisions are made quickly and are reversible where possible.

Eradication removes the cause: patching the exploited weakness, removing persistence, and rotating every credential that could have been observed. Rotation covers everything the compromised context could reach, not only what is known to have been used.

Recovery restores service from a known-good state, with heightened monitoring for at least 14 days. A system is returned to service only when the Incident Commander is satisfied the cause is understood, not when the symptom stops.

7. Regulatory notification

Any incident involving personal data is assessed by the Data Protection Officer within 24 hours for notification obligations. Client contracts may impose shorter deadlines than regulation; the Communications Lead checks both.

8. Post-incident review

Every SEV1 and SEV2 receives a written review within five business days, covering timeline, root cause, contributing factors, what worked, and what did not.

The review is blameless. It examines systems and processes, never individuals. An organisation that punishes the person who reported an incident learns about its next incident from a customer, or from a newspaper.